

ACTIVIDAD 01 – ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Participante: Margenys Basha Guedez Perez.

Programa: Hacker Women Council – Ethical Hacking.

Caso: Aurora Market.

Punto N.º 1: OBJETIVO DEL PENTEST

El objetivo concreto de realizar un pentest sobre Aurora Market es conocer el nivel de exposición real de su aplicación web frente a posibles ataques y determinar si existen debilidades que puedan comprometer la información, las cuentas de usuario o las funciones disponibles dentro de la plataforma.

La evaluación no se limitará a buscar vulnerabilidades de forma aislada. También permitira entender qué podría llegar a hacer una persona no autorizada si encuentra y aprovecha una debilidad. Por ejemplo, interesa conocer si será posible acceder a información de otro usuario, utilizar funciones que no corresponden al perfil asignado, evadir controles de autenticación o manipular información enviada desde la aplicación.

Otro objetivo importante es revisar el problema que previamente fue reportado por un usuario. En este momento no se puede afirmar que dicho comportamiento sea una vulnerabilidad. Por eso, durante el pentest se analizará técnicamente para determinar su origen, confirmar si representa un fallo de seguridad y, si se confirma, valorar el impacto que podría tener para Aurora Market.

El valor de esta evaluación para la empresa está en obtener una visión más clara de sus riesgos actuales. Los resultados permitirán distinguir qué controles están funcionando, qué debilidades requieren atención y cuáles deberán corregirse primero. De esta forma, el equipo técnico podrá tomar decisiones basadas en evidencia y no únicamente en suposiciones.

Finalmente, el pentest permitirá dejar cada hallazgo documentado con suficiente detalle para que el equipo de desarrollo pueda revisarlo posteriormente, reproducir el comportamiento de forma controlada y aplicar una corrección.

Punto N.º 2: ALCANCE

El alcance que se presenta a continuación, define lo que, si se incluirá en el ejercicio solicitado por Aurora Market, siendo el siguiente:

Dentro del Alcance	Fuera de Alcance
✓ Aplicación web de Aurora Market. ✓ Mecanismos de inicio de sesión y autenticación. ✓ Gestión de sesiones. ✓ Funcionalidades visibles y accesibles desde la plataforma. ✓ Roles, permisos y tipos de usuarios incluidos en las cuentas de prueba. ✓ Control de acceso entre diferentes perfiles. ✓ Manejo de datos enviados por los usuarios. ✓ Interacción de la aplicación con sus datos, siempre dentro del alcance autorizado. ✓ Comportamiento relacionado con el problema reportado inicialmente. ✓ Servicios de red asociados a la aplicación únicamente si sus direcciones IP o nombres de host han sido autorizados expresamente.	• Sistemas pertenecientes a terceros. • Servicios externos que no pertenezcan a Aurora Market. • Ingeniería social contra empleados o clientes. • Ataques de denegación de servicio o pruebas que puedan afectar deliberadamente la disponibilidad. • Instalaciones físicas de la empresa. • Dispositivos personales de trabajadores o clientes. • Sistemas, direcciones IP, dominios o subdominios no incluidos expresamente en la autorización. • Extracción, modificación o eliminación deliberada de información real.

Punto N.º 3: AUTORIZACIÓN Y CONDICIONES

Es imprescindible contar con los siguientes permisos para la ejecución del pentest, los cuales deben estar validados antes de la fecha de inicio del mismo por ambas partes:

- Autorización expresa y escrita de Aurora Market para realizar la evaluación.
- Identificación clara de los dominios, hosts, direcciones IP y componentes permitidos.
- Definición de las cuentas de prueba disponibles y de los perfiles que representan.
- Autorización para validar vulnerabilidades de manera controlada.
- Identificación de una matriz de escalamiento y de un contacto técnico para incidentes o afectaciones inesperadas.
- Definición del horario permitido para cada tipo de prueba.

Condiciones acordadas

- Las pruebas se limitarán a los activos incluidos en el alcance.
- No se realizarán acciones destinadas a interrumpir el servicio.
- No se eliminarán ni modificarán datos reales de clientes o de la empresa.
- La explotación se limitará a lo estrictamente necesario para confirmar un hallazgo.
- Las actividades con mayor carga sobre los sistemas se ejecutarán únicamente en la ventana acordada con Aurora Market.
- Si se identifica una vulnerabilidad crítica o una afectación inesperada, se notificará de inmediato a la matriz de escalamiento.
- Toda la información obtenida durante el pentest se tratará como confidencial.
- Los hallazgos se documentarán con evidencia suficiente para que puedan ser revisados por el equipo técnico.

Punto N.º 4: TIPO DE PENTEST

Se propone la realización del **Pentest Gray-box** debido a que se recibe información parcial sobre Aurora Market. Se conoce que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuarios, pero no se dispone de la arquitectura completa, el código fuente ni toda la configuración interna. Este enfoque permite trabajar con un nivel de conocimiento similar al que podría tener un usuario legítimo o un atacante con información previa, sin llegar a las condiciones de un White-box.

Punto N.º 5: PLANIFICACIÓN

1. Objetivos

Conocer la exposición de la plataforma, revisar autenticación y autorización, analizar el problema reportado y determinar el valor e impacto de los hallazgos que pudieran identificarse.

2. Alcance

Aplicación web, autenticación, sesiones, roles, permisos, entradas de usuario y componentes relacionados que hayan sido autorizados expresamente.

3. Permisos y condiciones

Autorización escrita, activos permitidos, cuentas de prueba, límites técnicos, horarios, tratamiento de la información y matriz de escalamiento.

4. Metodología a utilizar

Se utilizará una metodología estructurada de pentesting y, para la parte web, OWASP Web Security Testing Guide (WSTG) como referencia para organizar las pruebas. El propósito es mantener un proceso ordenado desde la recopilación de información hasta la elaboración del informe.

5. Recopilación de información previa

Antes de comenzar las pruebas técnicas se recopilará información que permita entender mejor el entorno de Aurora Market y evitar acciones innecesarias. Se combinarán fuentes internas, facilitadas por el cliente, con fuentes abiertas u OSINT.

Como fuentes internas se solicitarán los dominios e IP autorizadas, cuentas de prueba, descripción de los perfiles de usuario, funcionalidades principales, información disponible sobre el problema reportado, horarios de mayor y menor demanda, contactos técnicos y cualquier documentación que Aurora Market decida facilitar.

Como fuentes abiertas se consultarán datos públicos relacionados con el dominio, registros DNS, posibles subdominios y tecnologías visibles desde Internet. La idea es conocer qué información podría reunir una persona externa sin tener acceso interno.

Si las direcciones IP relacionadas con la aplicación están dentro del alcance, Nmap se utilizará durante el reconocimiento para identificar puertos y servicios expuestos. El propósito será saber qué servicios son accesibles desde la red y si existe una superficie de ataque adicional que deba revisarse.

Para la aplicación web se utilizará OWASP ZAP como proxy de análisis. Esto permitirá observar las solicitudes y respuestas entre el navegador y Aurora Market, así como identificar rutas, parámetros, cookies, cabeceras y otros elementos útiles para comprender el funcionamiento de la aplicación antes del análisis de vulnerabilidades.

6. Recursos y herramientas

En base a la solicitud realizada por Aurora Market, se plantea el desarrollo del ejercicio con las siguientes herramientas:

Herramienta / método	Etapas	Qué se busca conocer	Propósito en Aurora Market
WHOIS / consultas DNS	Recopilación / reconocimiento	Información pública del dominio, DNS y relación con infraestructura visible.	Conocer qué información puede obtenerse públicamente.
OSINT	Reconocimiento	Dominios, subdominios e información pública relacionada.	Ampliar la superficie conocida sin ejecutar pruebas intrusivas.
Nmap	Reconocimiento / enumeración	Puertos y servicios accesibles en hosts autorizados.	Identificar servicios expuestos además de la aplicación web.
OWASP ZAP	Reconocimiento web / análisis	Solicitudes, respuestas, rutas, parámetros, cookies y cabeceras.	Comprender el comportamiento de la aplicación y localizar elementos que deban revisarse.
Navegador / herramientas de desarrollador	Reconocimiento y validación manual	Comportamiento visible de la aplicación y diferencias entre perfiles.	Contrastar manualmente funciones y respuestas.
OWASP WSTG	Metodología	Casos de prueba organizados para aplicaciones web.	Guiar la revisión de autenticación, sesiones, autorización, entradas y lógica de negocio.

7. Programación del pentest

La programación debe considerar que Aurora Market es una tienda online y que cualquier afectación de disponibilidad puede impactar a usuarios reales y a la operación del negocio.

Las tareas de bajo impacto, como revisión documental, OSINT y análisis de información pública, podrán realizarse durante horario laboral porque no deberán generar una carga relevante sobre la plataforma.

Los escaneos o validaciones que puedan producir un mayor número de solicitudes se realizarán en una ventana de baja demanda previamente aprobada por Aurora Market. Como propuesta inicial se plantea su ejecución desde las 00:00 a 04:00 horas, pero este horario no se asumirá como definitivo: primero se confirmará con el cliente cuándo existe realmente menor tráfico.

La razón de utilizar una ventana de baja demanda es reducir el riesgo de afectar a clientes reales y facilitar que cualquier comportamiento inesperado pueda ser detectado y atendido rápidamente. También se deben definir los siguientes puntos antes de iniciar el pentest:

- Fecha de inicio y finalización.
- Horario autorizado para cada tipo de prueba.
- Responsable técnico de Aurora Market.
- Matriz de escalamiento y procedimiento de detención de pruebas.
- Tiempo destinado al análisis de resultados.
- Fecha de entrega del informe.

Punto N.º 6: FASES DEL PENTEST

1. Reconocimiento

La primera fase consistirá en recopilar información para entender cómo está expuesto Aurora Market y qué elementos podrían convertirse posteriormente en puntos de entrada. Se comenzará con la información proporcionada por la empresa: dominios autorizados, cuentas de prueba, tipos de usuario, funcionalidades principales y datos disponibles sobre el problema reportado. Después se complementará esa información mediante OSINT. Se revisarán datos públicos del dominio, registros DNS, posibles subdominios y tecnologías visibles desde Internet. El objetivo será observar la plataforma desde una perspectiva similar a la de una persona externa.

Si Aurora Market autoriza expresamente los hosts o direcciones IP correspondientes, se utilizará Nmap para identificar puertos y servicios accesibles. El análisis de puertos permitirá saber si, además del servicio web esperado, existen otros servicios expuestos y qué protocolos podrían requerir una revisión posterior. En esta etapa el objetivo no será atacar esos servicios.

Sobre la aplicación web se utilizará el navegador y OWASP ZAP como proxy. Se buscará conocer las rutas disponibles, formularios, parámetros enviados por el usuario, cookies, cabeceras HTTP, proceso de autenticación, diferencias entre perfiles, mensajes de error y posibles endpoints observados durante la navegación.

Al finalizar el reconocimiento existirá una visión más clara de la superficie de ataque: qué servicios están expuestos, cómo está organizada la aplicación, qué entradas recibe y cuáles son los elementos que requieren un análisis más profundo.

2. Análisis de vulnerabilidades

Con la información recopilada en el reconocimiento se revisarán los posibles puntos débiles de la aplicación. OWASP ZAP se utilizará como apoyo para analizar el tráfico HTTP/HTTPS y detectar elementos que requieran una revisión

manual más profunda. Se prestará especial atención a autenticación, gestión de sesiones, control de acceso entre usuarios, validación de entradas, manejo de errores, exposición innecesaria de información, cabeceras de seguridad y funciones disponibles según el rol. OWASP Web Security Testing Guide se utilizará como referencia para organizar las pruebas y evitar una revisión desordenada. Debido a que Aurora Market maneja distintos perfiles, será especialmente importante comparar el comportamiento de la aplicación entre cuentas de prueba.

Los resultados automáticos no se considerarán vulnerabilidades confirmadas por sí solos. Cada posible hallazgo se revisará manualmente para descartar falsos positivos y decidir cuáles requieren una validación controlada en la siguiente fase. En esta etapa todavía no se ejecutará la explotación. El propósito de esta etapa es definir cómo se identificarán y analizarán las posibles debilidades.

3. Explotación

Las posibles vulnerabilidades identificadas se validarán de manera controlada, únicamente dentro de los límites autorizados por Aurora Market.

El objetivo no será causar daño ni obtener el máximo acceso posible, sino comprobar si un hallazgo puede aprovecharse realmente y conocer su consecuencia. Por ejemplo, ante un posible problema de control de acceso, se intentará verificar si una cuenta de prueba puede acceder a información o funciones que corresponden a otro perfil.

La prueba se detendrá cuando exista evidencia suficiente para demostrar el comportamiento. A partir de ese punto se documentará el resultado y se evitarán acciones adicionales que no aporten valor a la evaluación.

4. Post-explotación

Si una vulnerabilidad queda confirmada, se analizará de forma controlada cuál podría ser su alcance. Se buscará entender qué información podría quedar expuesta, si podrían verse afectados otros usuarios, qué nivel de permisos podría alcanzarse y qué impacto tendría sobre la confidencialidad, integridad o disponibilidad. No se modificarán ni eliminarán datos reales. Tampoco se continuará avanzando por la plataforma si ya se dispone de evidencia suficiente.

Al finalizar se comprobará que no hayan quedado cambios, archivos, sesiones o configuraciones derivados de las pruebas.

5. Informe

Al finalizar la evaluación se entregará un informe que permita a Aurora Market comprender tanto el riesgo técnico como su posible impacto.

Cada hallazgo incluirá: título, descripción, activo afectado, evidencia, condiciones necesarias para que ocurra, nivel de riesgo, impacto posible, forma de reproducción controlada y recomendación de corrección. Además, se incluirá un resumen ejecutivo orientado a personas no técnicas, de manera que la empresa pueda entender qué riesgos son más relevantes y cuáles deberán atenderse primero.

Punto N.º 7: INVESTIGACIÓN

Se utilizará OWASP Web Security Testing Guide (WSTG) porque el principal componente conocido de Aurora Market es una aplicación web. WSTG ofrece una guía organizada para revisar áreas como recopilación de información, autenticación, autorización, gestión de sesiones, validación de entradas y lógica de negocio.

Para este escenario servirá como referencia para mantener un orden de trabajo y relacionar cada prueba con un propósito concreto. No significa que se deban ejecutar todas las pruebas de OWASP; se seleccionarán únicamente aquellas que tengan sentido dentro del alcance y las condiciones acordadas.